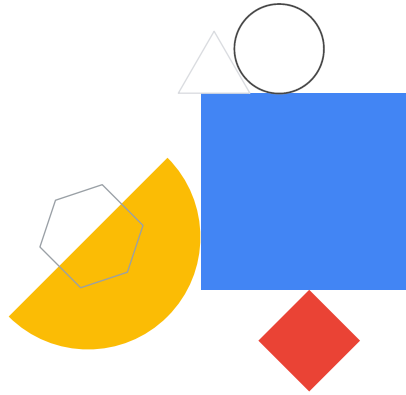


Identity and Access Management



이 모듈에서는 Identity and Access Management(즉, IAM)에 대해 알아봅니다.

IAM은 이메일과 비슷한 주소 이름, 작업 유형 역할 및 세분화된 권한을 기반으로 구축된 정교한 시스템입니다. 다른 구현에서의 IAM에 익숙하다면 Google에서 IAM을 더 안전하게 유지하고 쉽게 관리할 수 있도록 구현한 것과 어떤 차이가 있는지 확인해 보세요.

주제

01 Identity and Access Management(IAM)

02 조직

03 역할

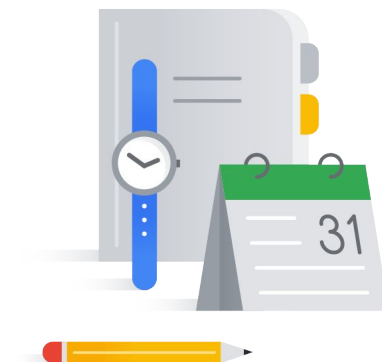
04 구성원

05 서비스 계정

06 조직 액세스 제한

07 IAM 권장사항

실습: IAM 살펴보기



먼저 **IAM**을 개략적으로 소개한 다음, **IAM**을 구성하는 요소인 조직, 역할, 구성원 및 서비스 계정에 대해 자세히 알아보겠습니다. 조직 액세스 제한 기능에 대해 이야기하고 일상 업무에 이러한 개념을 적용하는 데 도움이 되는 몇 가지 권장사항도 소개하겠습니다.

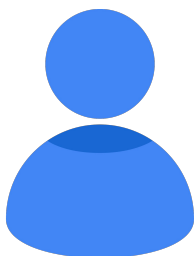
마지막에는 실습을 통해 **IAM**을 직접 경험해 보게 됩니다.

Identity and Access Management의 개요부터 시작해 볼까요?

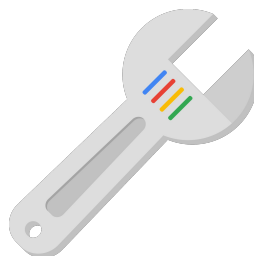


Identity and Access Management(IAM)

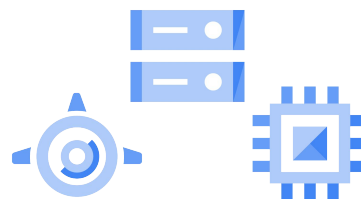
Identity and Access Management



누가



무엇을 할 수 있는지



어떤 리소스에서

Google Cloud

그렇다면 **Identity and Access Management**, 즉 ID 및 액세스 관리란 무엇일까요?
이는 누가 어떤 리소스에서 무엇을 할 수 있는지 식별하는 방법입니다.

'누가'는 사용자, 그룹 또는 애플리케이션이 될 수 있습니다. '무엇'은 특정 권한 또는 작업을 나타내며 어떤 **Google Cloud** 서비스든 '리소스'가 될 수 있습니다.

예를 들어 사용자에게 **Compute** 뷰어의 권한이나 역할을 부여할 수 있습니다. 해당 사용자는 **Compute Engine** 리소스에 저장된 데이터를 읽을 수는 없지만 리소스를 가져와 나열할 수 있는 읽기 전용 액세스 권한을 얻게 되죠.

IAM 객체



조직



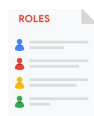
폴더



프로젝트



리소스



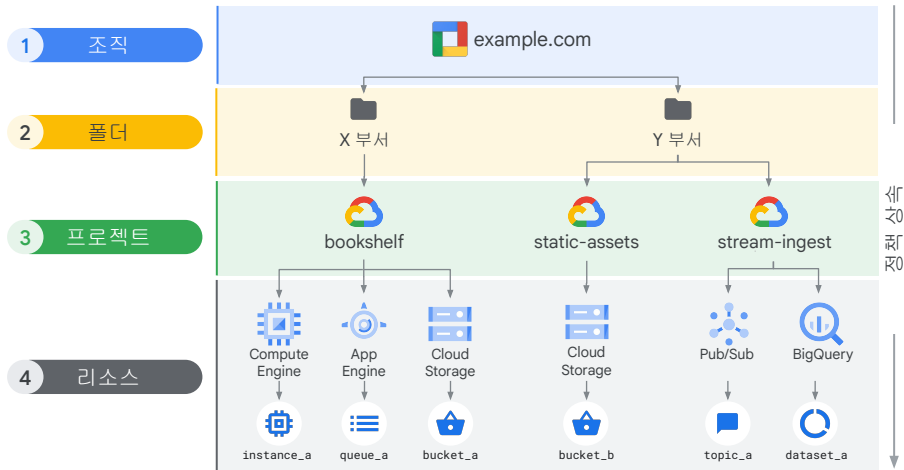
역할



구성원

IAM은 이 슬라이드에서 볼 수 있는 것처럼 다양한 객체로 구성됩니다. 이 모듈에서 이러한 객체를 각각 다룰 것입니다. **IAM** 정책과 **IAM** 리소스 계층 구조를 살펴보면서 이 객체들이 어디에 속하는지 알아보겠습니다.

IAM 리소스 계층 구조



Google Cloud

이 트리 구조에서 볼 수 있듯이 **Google Cloud** 리소스는 계층적으로 구성됩니다. 조직 노드는 이 계층의 루트 노드이고, 폴더는 조직의 하위 요소이고, 프로젝트는 폴더의 하위 요소이며, 개별 리소스는 프로젝트의 하위 요소입니다. 각 리소스는 단 하나의 상위 요소만 가집니다.

조직 리소스는 회사를 나타냅니다. 이 수준에서 부여된 **IAM** 역할은 조직의 모든 리소스에 상속됩니다.

폴더 리소스는 부서를 나타낼 수 있습니다. 이 수준에서 부여된 **IAM** 역할은 폴더에 포함된 모든 리소스에 상속됩니다.

프로젝트는 회사 내에서 신뢰 경계를 나타냅니다. 같은 프로젝트에 있는 서비스는 기본 신뢰 수준을 갖습니다.

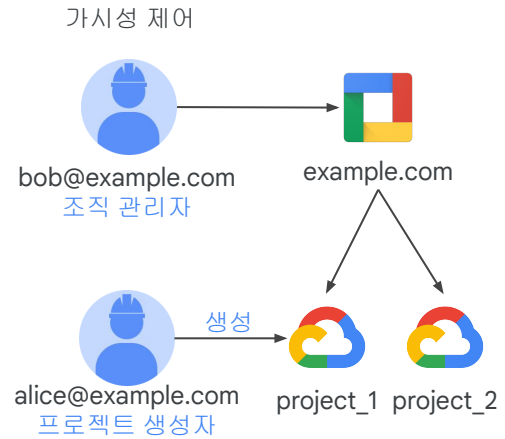


조직

조직 노드에 대해 자세히 알아보겠습니다.

조직 노드

- 조직 노드는 Google Cloud 리소스의 루트 노드입니다.
- 조직 역할:
 - 조직 관리자: 모든 클라우드 리소스를 제어할 수 있습니다. 감사에 유용합니다.
 - 프로젝트 생성자: 프로젝트의 생성을 제어할 수 있습니다. 누가 프로젝트를 생성할 수 있는지 제어합니다.



Google Cloud

앞에서 언급했듯이 조직 리소스는 Google Cloud 리소스 계층 구조의 루트 노드입니다. 이 노드에는 많은 역할이 있습니다. 조직 관리자도 그중 하나이죠.

조직 관리자는 밥과 같은 사용자에게 조직에 속한 모든 리소스를 관리할 수 있는 액세스 권한을 제공하므로 감사에 유용합니다.

앨리스와 같은 사용자가 조직 내에서 프로젝트를 생성할 수 있도록 하는 프로젝트 생성자 역할도 있습니다. 프로젝트 생성자 역할을 조직 수준에서도 적용할 수 있기 때문에 여기에 표시하며 모든 프로젝트에 상속됩니다.

조직 만들기 및 관리하기

- **Google Workspace** 또는 **Cloud ID** 계정이 Google Cloud 프로젝트를 생성하면 생성됨
- **Workspace** 또는 **Cloud ID** 최고 관리자:
 - 일부 사용자에게 조직 관리자 역할을 할당합니다.
 - 복구 문제가 발생할 경우 담당자 역할을 수행합니다.
 - **Workspace** 또는 **Cloud ID** 계정 및 조직 리소스의 수명 주기를 제어합니다.
- 조직 관리자:
 - IAM 정책을 정의합니다.
 - 리소스 계층 구조를 결정합니다.
 - IAM 역할을 통해 네트워킹, 결제 및 리소스 계층 구조와 같은 중요한 구성요소에 대한 책임을 위임합니다.

Google Cloud

조직 리소스는 **Google Workspace** 또는 **Cloud ID** 계정과 긴밀하게 연결됩니다.

Workspace 또는 **Cloud ID** 계정을 가진 사용자가 **Google Cloud** 프로젝트를 만들면 조직 리소스가 자동으로 프로비저닝됩니다. 그런 다음 **Google Cloud**는 **Workspace** 또는 **Cloud ID** 최고 관리자에게 조직에서 사용할 수 있다는 사실을 알립니다. 이러한 최고 관리자 계정은 조직과 조직의 모든 리소스를 제어할 수 있으므로 신중하게 사용해야 합니다.

Google Workspace 또는 **Cloud ID** 최고 관리자와 **Google Cloud** 조직 관리자는 설정 프로세스 및 조직 리소스의 수명 주기를 제어하는 데 있어 핵심 역할입니다. 조직의 구조와 요구에 따라 다르지만 두 역할은 일반적으로 서로 다른 사용자나 그룹에 할당됩니다.

Google Cloud 조직 설정 시 **Workspace** 또는 **Cloud ID** 최고 관리자의 책임은 다음과 같습니다.

- 일부 사용자에게 조직 관리자 역할을 할당합니다.
- 복구 문제가 발생할 경우 담당자 역할을 수행합니다.
- **Workspace** 또는 **Cloud ID** 계정 및 조직 리소스의 수명 주기를 제어합니다.

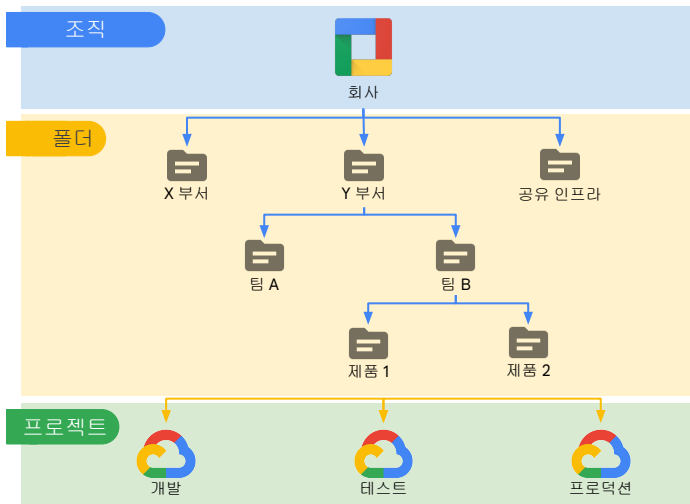
조직 관리자 역할의 책임은 다음과 같습니다.

- IAM 정책을 정의합니다.
- 리소스 계층 구조를 결정합니다.

- IAM 역할을 통해 네트워킹, 결제 및 리소스 계층 구조와 같은 중요한 구성요소에 대한 책임을 위임합니다.

최소 권한의 원칙에 따라 폴더 만들기과 같은 다른 작업을 수행할 수 있는 권한은 이 역할에 포함되지 않습니다. 이 권한을 얻으려면 조직 관리자가 계정에 추가 역할을 할당해야 합니다. 조직 생성 및 관리에 대한 자세한 내용은 이 [안내 가이드](#)를 참조하세요.

폴더



프로젝트 간의 추가 그룹화
메커니즘 및 격리 경계:

- 다양한 법인
- 부서
- 팀

폴더를 통해 관리 권한을 위임할 수 있습니다.

Google Cloud

조직 내 하위 조직으로 볼 수 있는 폴더에 대해 더 자세히 설명하겠습니다.

폴더는 프로젝트 간의 추가 그룹화 메커니즘 및 격리 경계를 제공합니다. 폴더는 회사 내의 다양한 법인, 부서, 팀을 모델링하는 데 사용할 수 있습니다. 예를 들어 폴더의 첫 번째 수준을 사용하여 X 부서, Y 부서와 같은 조직의 주요 부서를 나타낼 수 있습니다.

폴더는 프로젝트와 다른 폴더를 포함할 수 있으므로 각 폴더는 팀 A와 B 같은 다른 팀을 나타내는 다른 하위 폴더를 포함할 수 있습니다.

각 팀 폴더는 제품 1, 2와 같은 다른 애플리케이션을 나타내는 추가적인 하위 폴더를 포함할 수 있습니다.

폴더를 사용하여 관리 권한을 위임할 수 있으므로 부서 책임자에게 해당 부서에 속하는 모든 Google Cloud 리소스의 완전한 소유권을 부여할 수 있습니다. 이와 유사하게 리소스에 대한 액세스 권한은 폴더별로 제한할 수 있으므로 한 부서의 사용자는 해당 폴더 내의 Google Cloud 리소스만 액세스하고 만들 수 있습니다.

리소스 관리자 역할

조직

- 관리자: 모든 리소스를 완전히 제어
- 뷰어: 모든 리소스에 대한 보기 권한

폴더

- 관리자: 모든 폴더를 완전히 제어
- 작성자: 계층 구조 탐색 및 폴더 생성
- 뷰어: 리소스 아래의 폴더 및 프로젝트 보기

프로젝트

- 작성자: 새 프로젝트 생성(자동 소유자) 및 새 프로젝트를 조직으로 마이그레이션
- 삭제자: 프로젝트 삭제

생성
읽기
삭제

정책은 위에서 아래로 상속된다는 점을 기억하면서 다른 리소스 관리자 역할을 살펴보겠습니다.

조직 노드에는 조직 내의 모든 리소스에 대한 보기 권한을 부여하는 뷰어 역할도 있습니다.

폴더 노드에 있는 여러 역할은 조직 노드에 있는 역할을 모방하지만 폴더 내의 리소스에만 적용됩니다. 폴더에 대한 모든 권한을 제공하는 관리자 역할, 계층을 탐색하고 폴더를 생성할 수 있는 생성자 역할, 리소스 아래에 있는 폴더와 프로젝트를 볼 수 있는 뷰어 역할이 있습니다.

마찬가지로 프로젝트에도 사용자가 새 프로젝트를 생성하면 해당 사용자를 자동으로 소유자로 만드는 생성자 역할이 있습니다. 이에 더해, 프로젝트에 대한 삭제 권한을 부여하는 프로젝트 삭제자 역할이 있습니다.



역할

IAM의 '어떤 리소스에서 무엇을 할 수 있는지'를 정의하는 역할에 대해 좀 더 이야기해 보겠습니다.

IAM 역할의 세 가지 유형

기본 역할



사전 정의된 역할



커스텀 역할



IAM에는 기본 역할, 사전 정의된 역할, 커스텀 역할이라는 세 가지 역할 유형이 있습니다.

프로젝트의 모든 **Google Cloud** 서비스에 적용되는 **IAM** 기본 역할



무엇을 할 수 있는지

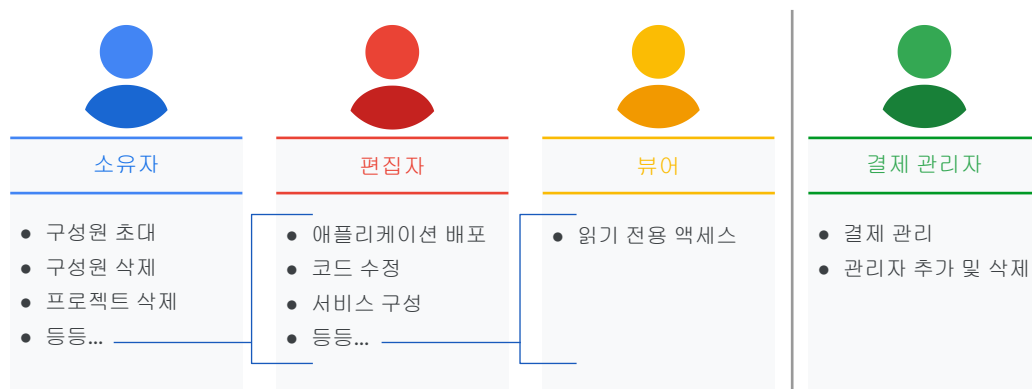


모든 리소스에서

기본 역할은 **Google Cloud** 콘솔에서 사용할 수 있었던 원래 역할이지만
광범위합니다.

기본 역할을 **Google Cloud** 프로젝트에 적용하면 해당 프로젝트의 모든 리소스에
영향을 줍니다.

대략적인 고정 액세스 수준을 제공하는 IAM의 기본 역할



Google Cloud

즉, IAM 기본 역할은 대략적인 고정 액세스 수준을 제공합니다.

소유자, 편집자, 뷰어 역할이 기본 역할에 해당합니다.

- 소유자 역할은 전체 관리 액세스 권한이 있습니다. 여기에는 구성원을 추가 및 제거하고 프로젝트를 삭제할 수 있는 기능이 포함됩니다.
- 편집자 역할은 수정 및 삭제 액세스 권한이 있습니다. 이를 통해 개발자는 애플리케이션을 배포하고 관련 리소스를 수정하거나 구성할 수 있습니다.
- 뷰어 역할은 읽기 전용 액세스 권한이 있습니다.

이 모든 역할의 권한은 동심원 형태로 겹칩니다. 즉, 소유자 역할에는 편집자 역할의 권한이 포함되며, 편집자 역할에는 뷰어 역할의 권한이 포함됩니다.

또한 결제 관리자 역할도 있습니다. 이 역할은 프로젝트의 리소스를 변경하는 권한은 없지만 결제를 관리하고 관리자를 추가 또는 제거할 수 있습니다.

각 프로젝트에는 여러 명의 소유자, 편집자, 뷰어 및 결제 관리자가 있을 수 있습니다.

프로젝트의 특정 Google Cloud 서비스에 적용되는 IAM의 사전 정의된 역할



무엇을 할 수 있는지



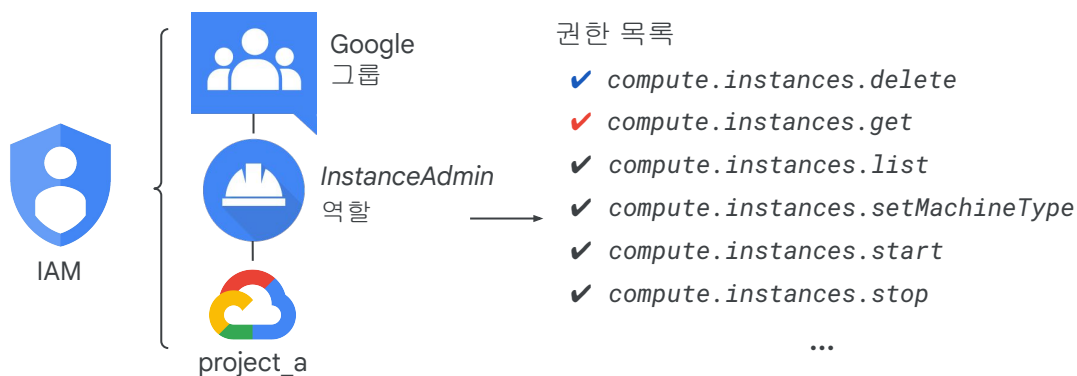
이 프로젝트, 폴더 또는 조직의 Compute Engine 리소스에서

Google Cloud

Google Cloud 서비스는 사전 정의된 고유한 역할 집합을 제공합니다. 해당 역할을 어디에 적용할 수 있는지도 정의되어 있죠. 이는 구성원에게 특정 Google Cloud 리소스에 대한 세부적인 액세스 권한을 부여하고 다른 리소스에 대한 무단 액세스를 방지합니다.

의미 있는 작업을 수행하려면 일반적으로 둘 이상의 권한이 필요하기 때문에 이러한 역할은 여러 권한을 모아 둔 형태입니다.

특정 서비스에 대해 보다 세분화된 권한을 제공하는 IAM의 사전 정의된 역할



Google Cloud

여기에 나와 있는 예시에는 사용자 그룹에 **project_a**에 대한 **InstanceAdmin** 역할이 부여되어 있습니다. 이렇게 하면 해당 그룹의 사용자에게 오른쪽에 나열된 모든 **Compute Engine** 권한을 비롯한 다양한 권한이 제공됩니다. 이러한 권한을 역할로 그룹화하면 더 쉽게 관리할 수 있습니다. 권한 자체는 **API**의 클래스 및 메서드입니다.

예를 들어 **compute.instances.start**는 서비스, 리소스, 동사로 나눌 수 있습니다. 즉, 이 권한은 중지된 **Compute Engine** 인스턴스를 시작하는 데 사용됩니다.

이러한 권한은 일반적으로 작업의 해당 **REST API**와 일치합니다.

Compute Engine IAM 역할

역할 이름	설명
Compute 관리자	모든 Compute Engine 리소스를 관리할 수 있는 전체 권한(compute.*)
네트워크 관리자	방화벽 규칙과 SSL 인증서를 제외한 네트워킹 리소스를 생성, 수정, 삭제할 수 있는 권한
스토리지 관리자	디스크, 이미지, 스냅샷을 생성, 수정, 삭제할 수 있는 권한

Google Cloud

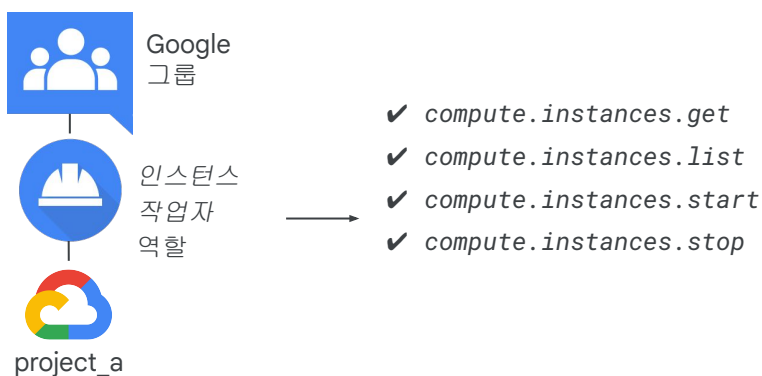
Compute Engine에는 사전 정의된 여러 IAM 역할이 있습니다. 그중 세 가지를 살펴보겠습니다.

- **Compute 관리자** 역할은 모든 **Compute Engine** 리소스를 관리할 수 있는 전체 권한을 제공합니다. 여기에는 **compute**로 시작하는 모든 권한이 포함됩니다. 즉, 모든 유형의 **Compute Engine** 리소스에 대한 모든 작업이 허용됩니다.
- **네트워크 관리자** 역할에는 방화벽 규칙 및 **SSL** 인증서를 제외한 네트워킹 리소스를 생성, 수정 및 삭제할 수 있는 권한이 포함됩니다. 다시 말해, 네트워크 관리자 역할은 방화벽 규칙, **SSL** 인증서, 인스턴스에 대한 읽기 전용 액세스 권한은 허용하므로 임시 **IP** 주소를 볼 수 있습니다.
- **스토리지 관리자** 역할에는 디스크, 이미지 및 스냅샷을 생성, 수정 및 삭제할 수 있는 권한이 포함됩니다.

예를 들어 회사에서 프로젝트 이미지를 관리하는 담당자에게 프로젝트에 대한 편집자 역할을 부여하지 않으려면 해당 계정에 프로젝트에 대한 스토리지 관리자 역할을 부여하면 됩니다. **Compute Engine**의 사전 정의된 역할의 전체 목록은 이 [문서 페이지](#)를 참조하세요.

역할은 추상적인 기능을 나타내기 위한 것이며 실제 작업에 맞게 맞춤설정됩니다. 그러나 이러한 역할 중 하나에 충분한 권한이 없거나 더 세분화된 역할이 필요한 경우에는 어떻게 해야 할까요?

IAM 커스텀 역할을 통해 정확한 권한 집합을 정의할 수 있음



Google Cloud

커스텀 역할로 할 수 있는 것은 이와 같습니다. 많은 회사에서 조직의 각 사용자에게 작업을 수행하는 데 필요한 최소한의 권한을 부여하는 '최소 권한' 모델을 사용합니다.

Compute Engine 가상 머신을 시작 및 중지할 수 있지만 재구성할 수는 없게 하는 '인스턴스 작업자' 역할을 정의한다고 가정해 보겠습니다. 커스텀 역할을 사용하면 이를 수행할 수 있습니다.

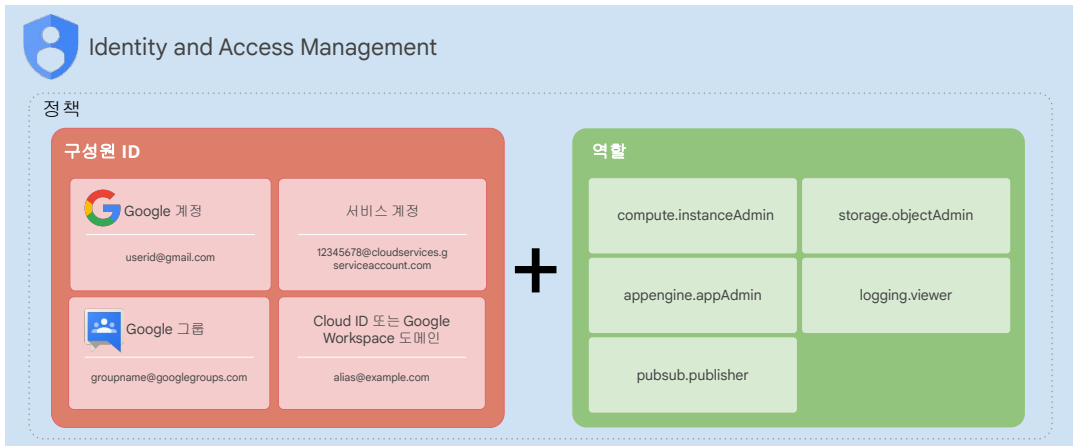
Google Cloud에서 커스텀 역할을 만드는 방법에 대한 데모는 이 [동영상](#)을 참조하세요.



구성원

'누가 어떤 리소스에서 무엇을 할 수 있는지'에서 '누가' 부분에 해당하는 구성원에 대해 좀 더 이야기해 보겠습니다.

구성원



참고: IAM을 사용자 또는 그룹을 생성하거나 관리하는 데 사용할 수 없습니다.

Google Cloud

구성원에는 5가지 유형, 즉 **Google 계정**, **서비스 계정**, **Google 그룹스**, **Google Workspace 도메인**, **Cloud ID 도메인**이 있습니다.

Google 계정은 개발자, 관리자, **Google Cloud**와 상호작용하는 다른 모든 사람을 나타냅니다. **gmail.com** 및 기타 도메인을 비롯하여 **Google 계정**과 연결된 모든 이메일 주소는 **ID**가 될 수 있습니다. 신규 사용자는 **Gmail**을 통해 메일을 수신하지 않고 **Google 계정 가입 페이지**로 이동하여 **Google 계정**에 가입할 수 있습니다.

서비스 계정은 개별 최종 사용자가 아니라 애플리케이션에 속한 계정입니다. **Google Cloud**에서 호스팅되는 코드를 실행할 때는 코드를 실행하는 계정을 지정하게 됩니다. 애플리케이션의 다양한 논리적 구성요소를 나타내는 데 필요한 만큼 **서비스 계정**을 생성할 수 있습니다.

Google 그룹은 여러 **Google 계정**과 **서비스 계정**을 모아 이름을 붙인 계정 컬렉션입니다. 모든 그룹에는 그룹과 연결된 고유 이메일 주소가 있습니다. **Google 그룹스**를 사용하면 여러 사용자 컬렉션에 액세스 정책을 편리하게 적용할 수 있습니다. 개별 사용자 또는 **서비스 계정**에 대해 한 번에 하나씩 액세스 제어 권한을 부여하거나 변경하는 대신 전체 그룹에 대해 액세스 제어 권한을 한 번에 부여하고 변경할 수 있습니다.

Workspace 도메인은 조직의 **Workspace 계정**에서 생성된 모든 **Google 계정**의 가상

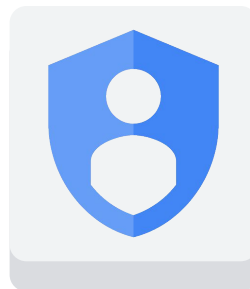
그룹을 나타냅니다. **Workspace** 도메인은 조직의 인터넷 도메인 이름(예: **example.com**)을 나타내며 **Workspace** 도메인에 사용자를 추가하면 해당 가상 그룹 내의 사용자를 위해 새로운 **Google** 계정이 생성됩니다(예: **username@example.com**).

Workspace 고객이 아닌 **Google Cloud** 고객은 **Cloud ID**를 통해 이와 동일한 기능을 사용할 수 있습니다. **Cloud ID**를 사용하면 **Google** 관리 콘솔을 사용하여 사용자 및 그룹을 관리할 수 있지만 **Gmail**, **Docs**, **Drive**, **Calendar**와 같은 **Workspace**의 공동작업 제품에 대한 비용을 지불하지 않으며 이러한 제품이 제공되지도 않습니다. **Cloud ID** 버전에 대한 자세한 내용은 이 [문서](#)를 참조하세요.

한 가지 유의해야 할 점은 사용자 또는 그룹을 생성하거나 관리하는 데 **IAM**을 사용할 수 없다는 것입니다. 대신 **Cloud ID** 또는 **Workspace**를 사용하여 사용자를 생성하고 관리할 수 있습니다.

IAM 정책

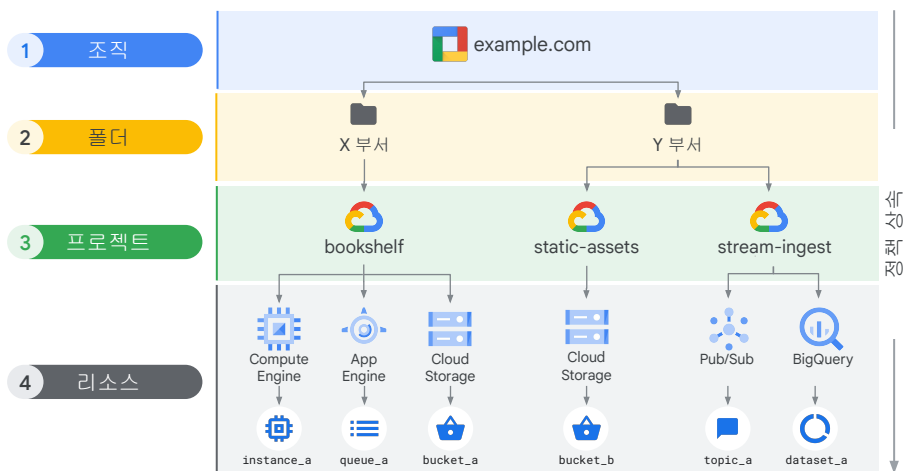
- 정책은 바인딩의 목록으로 구성됩니다.
- 바인딩은 구성원 목록을 역할에 연결합니다.



정책은 바인딩의 목록으로 구성됩니다.

바인딩은 구성원의 목록을 역할에 바인딩합니다. 구성원은 사용자 계정, **Google** 그룹, **Google** 도메인, 서비스 계정이 될 수 있습니다. 역할은 **IAM**에 의해 정의되는 명명된 권한 목록입니다. **IAM** 리소스 계층 구조를 다시 살펴보겠습니다.

IAM 리소스 계층 구조



Google Cloud

정책은 리소스에 연결된 액세스 구문의 모음입니다.

각 정책에는 상위 항목으로부터 정책을 상속하는 리소스와 함께 일련의 역할과 역할 구성원이 포함됩니다. 이렇게 생각해 보세요. 리소스 정책은 *리소스*와 *상위 리소스*의 집합이며 *덜* 제한적인 상위 정책이 항상 *더* 제한적인 리소스 정책을 재정의합니다.

IAM 정책 계층 구조는 항상 **Google Cloud** 리소스 계층 구조와 동일한 경로를 따릅니다. 즉, 리소스 계층 구조를 변경하면 정책 계층 구조도 변경됩니다. 예를 들어 프로젝트를 다른 조직으로 이동하면 새 조직의 **IAM** 정책을 상속하도록 프로젝트의 **IAM** 정책이 업데이트됩니다.

또한 하위 정책은 상위 수준에서 허용된 액세스 권한을 제한할 수 없습니다. 예를 들어 **X 부서**에 대한 편집자 역할을 부여받고 **bookshelf** 프로젝트 수준에서 뷰어 역할을 부여받는 경우 해당 프로젝트에 대한 편집자 역할은 계속 유지됩니다. 따라서 최소 권한의 원칙을 따르는 것이 가장 좋습니다. 이 원칙은 **ID**, 역할 및 리소스에 적용됩니다. 위험에 노출될 가능성을 줄이려면 항상 작업에 필요한 가장 작은 범위를 선택하세요.

또한 역할 권장사항에 추천자를 사용하여 주 구성원의 초과 권한을 식별하고 제거하여 리소스의 보안 구성을 개선할 수 있습니다. 각 역할 권장사항은 주 구성원에게 초과 권한을 부여하는 역할을 삭제하거나 대체할 것을 제안합니다. 규모에 맞게 이러한 권장사항은 주 구성원에 실제로 필요한 권한만 부여하여 최소 권한의 원칙을 적용하는 데 도움이 됩니다.

추천자는 정책 통계를 사용하여 초과 권한을 식별합니다. 정책 통계는 프로젝트, 폴더, 조직의 권한 사용에 대한 ML 기반 발견 항목입니다.
자세한 내용은 [문서 페이지](#)를 참조하세요.

IAM 허용 정책

- Google Cloud 리소스에 대해 액세스 권한 부여
- 리소스 자체 및 해당 리소스의 하위 요소에 대한 액세스 제어
- 단일 IAM 역할을 1명 이상의 주 구성원 (구성원 또는 ID라고도 함)과 연결하거나 바인딩

```
{
  "bindings": [
    {
      "members": [
        "user:jie@example.com"
      ],
      "role": "roles/resourcemanager.organizationAdmin"
    },
    {
      "members": [
        "user:raha@example.com",
        "user:jie@example.com"
      ],
      "role": "roles/resourcemanager.projectCreator"
    }
  ],
  "etag": "BwUjMhCsNvY=",
  "version": 1
}
```

Google Cloud

리소스에 연결된 **IAM(Identity and Access Management)** 정책으로도 알려진 허용 정책을 사용하여 **Google Cloud** 리소스에 대해 액세스 권한을 부여할 수 있습니다.

허용 정책은 리소스 자체뿐 아니라 허용 정책을 상속하는 해당 리소스의 모든 하위 요소에 대한 액세스를 제어합니다.

허용 정책은 역할이 부여되는 방법 및 시기를 변경하는 모든 상황별 조건과 단일 **IAM** 역할을 1명 이상의 주 구성원(구성원 또는 ID라고도 함)과 연결하거나 바인딩합니다.

이 슬라이드의 예시에서는 **Jie(jie@example.com)**가 첫 번째 역할 바인딩에서 사전 정의된 조직 관리자 역할(**roles/resourcemanager.organizationAdmin**)을 부여받았습니다. 이 역할에는 조직, 폴더, 제한된 프로젝트 작업에 대한 권한이 포함됩니다.

두 번째 역할 바인딩에서는 **Jie**와 **Raha(raha@example.com)** 모두 프로젝트 생성자 역할(**roles/resourcemanager.projectCreator**)을 통해 프로젝트를 생성할 수 있는 권한을 부여받습니다. 이러한 역할 바인딩은 **Jie**와 **Raha** 모두에게 세밀한 액세스 권한을 부여하며, **Jie**에게는 **Raha**보다 더 많은 액세스 권한이 부여됩니다.

IAM 거부 정책

거부 규칙은 부여된 역할에 관계없이 특정 주 구성원이 특정 권한을 사용하지 못하게 할 수 있습니다.

거부 정책은 거부 규칙으로 구성됩니다. 각 거부 규칙은 다음을 지정합니다.

- 권한이 거부된 주 구성원 집합
- 주 구성원이 거부되거나 사용할 수 없는 권한
- 선택사항: 권한이 거부되려면 반드시 '참'이어야 하는 조건

권한이 거부된 주 구성원은 해당 권한이 필요한 작업을 수행할 수 없게 됩니다.

Google Cloud

IAM 거부 정책을 사용하면 Google Cloud 리소스에 대한 액세스에 가드레일을 설정할 수 있습니다.

거부 정책을 사용하면 부여된 역할에 관계없이 특정 주 구성원이 특정 권한을 사용하지 못하게 하는 거부 규칙을 정의할 수 있습니다.

거부 정책은 거부 규칙으로 구성됩니다. 각 거부 규칙은 다음을 지정합니다.

- 권한이 거부된 주 구성원 집합
- 주 구성원이 거부되거나 사용할 수 없는 권한
- 선택사항: 권한이 거부되려면 반드시 '참'이어야 하는 조건

부여된 IAM 역할에 관계없이 권한이 거부된 주 구성원은 해당 권한이 필요한 작업을 수행할 수 없게 됩니다. 이는 IAM이 관련 허용 정책을 확인하기 전에 항상 관련 거부 정책을 검사하기 때문입니다.

IAM 조건

Google Cloud 리소스에 대한 속성 기반 조건부 액세스 제어를 시행합니다.

- 구성된 조건을 충족하는 경우에 한해 ID(구성원)에게 리소스에 액세스할 권한을 부여합니다.
- 리소스의 IAM 정책 중 역할 바인딩에서 지정됩니다.

Google Cloud

IAM 조건을 사용하면 Google Cloud 리소스에 조건부 속성 기반 액세스 제어를 정의하고 적용할 수 있습니다.

IAM 조건에서는 구성된 조건을 충족하는 경우에 한해 리소스 액세스를 ID(구성원)에게 부여하도록 선택할 수 있습니다. 예를 들어 프로덕션 문제가 발생하여 사용자에게 임시 액세스를 구성해야 하는 경우, 혹은 회사 사무실에서 요청하는 직원만 리소스에 액세스하도록 제한해야 하는 경우에 이러한 선택이 가능합니다.

조건은 리소스의 IAM 정책 중 역할 바인딩에서 지정됩니다. 조건이 있는 경우 조건 표현식이 true로 평가되어야만 액세스 요청이 승인됩니다. 각 조건 표현식은 논리문의 집합으로 정의되므로 검사할 1개 이상의 속성을 지정할 수 있습니다.

조직 정책

조직 정책은...

- 제한사항의 구성입니다.
- 원하는 제한사항으로 제약조건을 구성하여 정의됩니다.
- 조직 노드, 폴더 또는 프로젝트에 적용됩니다.

조직 정책은 제한사항의 구성으로, 해당 조직에 대해 원하는 제한사항으로 제약조건을 구성하여 정의합니다.

조직 정책은 조직 노드와 해당 노드 내의 모든 폴더나 프로젝트에 적용할 수 있습니다. 대상 리소스 계층 구조 노드의 하위 요소는 상위 요소에 적용된 조직 정책을 상속합니다.

이러한 정책에 대한 예외는 조직 정책 관리자 역할이 있는 사용자만 만들 수 있습니다.

이미 다른 회사 디렉터리가 있는 경우



이미 다른 회사 디렉터리가 있는 경우에는 어떨까요? 사용자와 그룹을 **Google Cloud**로 가져오려면 어떻게 해야 할까요?

관리자는 **Google Cloud** 디렉터리 동기화를 통해 이미 사용 중인 사용자 이름과 비밀번호를 그대로 사용하여 로그인하고 **Google Cloud** 리소스를 관리할 수 있습니다. 이 도구는 기존 **Active Directory** 또는 **LDAP** 시스템의 사용자 및 그룹을 **Cloud ID** 도메인의 사용자 및 그룹과 동기화합니다.

동기화는 단방향입니다. 즉, **Active Directory** 또는 **LDAP** 맵의 정보는 수정되지 않습니다. **Google Cloud** 디렉터리 동기화는 동기화 규칙이 설정된 후 감독 없이 예약된 동기화를 실행하도록 설계되었습니다.

싱글 사인온(SSO)

- Cloud ID를 사용하여 SAML SSO를 구성합니다.
- SAML2가 지원되지 않는 경우 서드 파티 솔루션(ADFS, Ping 또는 Okta)을 사용합니다.

Google Cloud

Google Cloud는 싱글 사인온(SSO) 인증도 제공합니다.

ID 시스템이 있다면 SSO를 구성하여 자체 시스템 및 프로세스를 계속 사용할 수 있습니다. 사용자 인증이 필요한 경우 Google에서 시스템으로 리디렉션합니다. 사용자가 시스템에서 인증되면 Google Cloud에 대한 액세스 권한이 부여됩니다. 그렇지 않을 경우 사용자에게 로그인하라는 메시지가 표시됩니다.

이를 통해 Google Cloud에 대한 액세스 권한을 취소할 수도 있습니다.

기존 인증 시스템이 SAML2를 지원하는 경우 이 슬라이드에 나와 있는 것처럼 링크 3개와 인증서 1개만으로도 간단하게 SSO를 구성할 수 있습니다. 아니면 ADFS, Ping 또는 Okta와 같은 타사 솔루션을 사용하는 방법도 있습니다.

기존 ID 관리 시스템 사용에 관한 자세한 내용은 이 [문서 페이지](#)를 참조하세요.

Gmail을 사용하지 않는 Google Cloud 액세스

- Gmail 없이도 Google 비밀번호를 얻을 수 있습니다.
- 도메인이 있으면 그룹 권한을 비롯해 여러 가지 이점이 있습니다.

Google Cloud

또한 Google 계정을 사용하고 싶지만 Gmail로 메일을 수신하고 싶지 않다면 Gmail 없이 계정을 만들 수 있습니다. 이에 대한 자세한 내용은 이 [페이지](#)를 참조하세요.



서비스 계정

앞서 언급했듯이 구성원의 또 다른 유형은 서비스 계정입니다.

서비스 간 상호작용을 수행하기 위한 ID를 제공하는 서비스 계정

- **Compute Engine** 인스턴스 내에서 실행되는 프로그램은 사용자 인증 정보가 있는 액세스 토큰을 자동으로 얻을 수 있습니다.
- 토큰은 프로젝트의 모든 서비스 **API** 및 해당 서비스 계정에 액세스 권한이 부여된 기타 서비스에 액세스하는 데 사용됩니다.
- 서비스 계정은 사용자 데이터에 액세스하지 않을 경우에 편리합니다.

Google Cloud

서비스 계정은 개별 최종 사용자가 아니라 애플리케이션에 속한 계정입니다. 사용자 인증 정보를 제공하지 않은 채 프로젝트에서 서비스 간 상호작용을 수행하기 위한 ID를 제공합니다.

예를 들어 **Google Cloud Storage**와 상호작용하는 애플리케이션을 작성하는 경우 먼저 **Google Cloud Storage XML API** 또는 **JSON API**에 인증해야 합니다.

서비스 계정을 사용 설정하고 애플리케이션을 실행하려는 인스턴스의 계정에 읽기/쓰기 액세스 권한을 부여할 수 있습니다.

그런 다음 서비스 계정에서 사용자 인증 정보를 얻도록 애플리케이션을 프로그래밍합니다. 애플리케이션은 인스턴스, 이미지, 애플리케이션 코드에 보안 비밀 키나 사용자 인증 정보를 삽입하지 않고도 **API**에 원활하게 인증됩니다.

이메일 주소로 식별되는 서비스 계정

- 123845678986-compute@project.gserviceaccount.com
- 세 가지 유형의 서비스 계정:
 - 사용자 생성(커스텀)
 - 기본 제공
 - **Compute Engine** 및 **App Engine** 기본 서비스 계정
 - **Google API** 서비스 계정
 - 사용자를 대신하여 내부 **Google** 프로세스 실행

Google Cloud

서비스 계정은 여기에 표시된 예와 같이 이메일 주소로 식별됩니다.

서비스 계정에는 사용자 생성(커스텀), 기본 제공, **Google API** 서비스 계정이라는 세 가지 유형이 있습니다.

기본적으로 모든 프로젝트에는 **Compute Engine** 기본 제공 서비스 계정이 제공됩니다.

기본 서비스 계정 외에 모든 프로젝트에는 이메일 (project-number@cloudservices.gserviceaccount.com)로 식별할 수 있는 **Google Cloud API** 서비스 계정이 제공됩니다. 이는 사용자를 대신하여 내부 **Google** 프로세스를 실행하도록 특별히 설계된 서비스 계정이며 프로젝트의 편집자 역할이 자동으로 부여됩니다.

또는 커스텀 서비스 계정으로 인스턴스를 시작할 수도 있습니다. 커스텀 서비스 계정은 기본 서비스 계정보다 더 높은 유연성을 제공하지만 더 많은 관리가 필요합니다. 커스텀 서비스 계정을 필요한 만큼 생성하고, 임의의 액세스 범위 또는 **IAM** 역할을 할당하고, 서비스 계정을 가상 머신 인스턴스에 할당할 수 있습니다.

기본 Compute Engine 서비스 계정

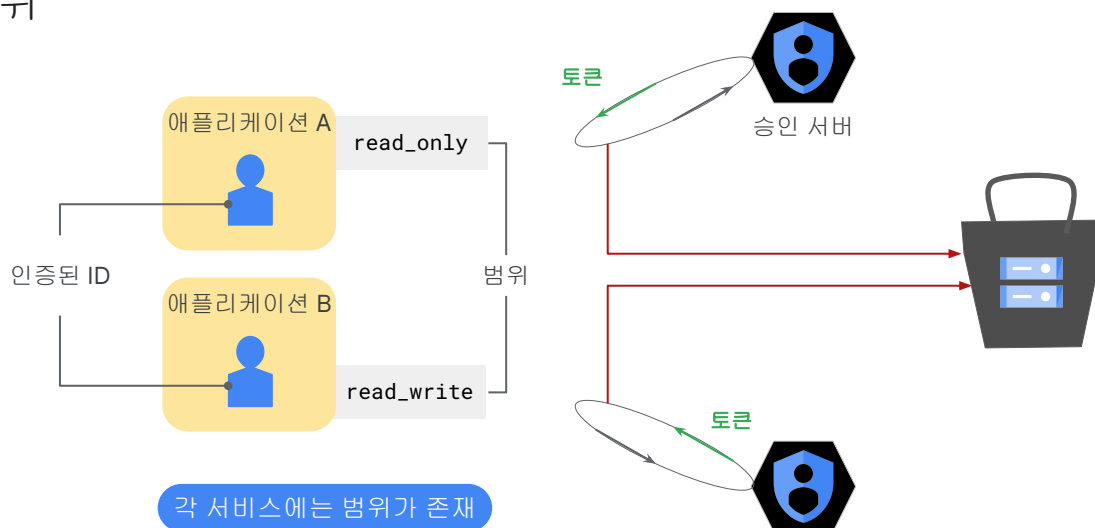
- 자동 생성된 이름 및 이메일 주소를 사용하여 프로젝트별로 자동 생성:
 - 이름에 `-compute` 접미사가 있습니다.
`39xxxx0965-compute@developer.gserviceaccount.com`
- 프로젝트 편집자로 자동 추가됨
- 기본적으로 `gcloud` 또는 Google Cloud 콘솔을 사용하여 생성된 모든 인스턴스에서 사용 설정됨

Google Cloud

기본 Compute Engine 서비스 계정에 대해 자세히 알아보겠습니다. 앞서 언급한 것처럼 이 계정은 프로젝트별로 자동으로 생성됩니다. 이 계정은 이메일 project-number-compute@developer.gserviceaccount.com으로 식별할 수 있으며 프로젝트에 대한 편집자 역할이 자동으로 부여됩니다.

`gcloud`를 사용하여 새 인스턴스를 시작하면 해당 인스턴스에서 기본 서비스 계정이 사용 설정됩니다. 다른 서비스 계정을 지정하거나 인스턴스의 서비스 계정을 사용 중지하여 이 동작을 재정의할 수 있습니다.

범위



각 서비스에는 범위가 존재

승인은 지정된 리소스 조합에 대해 인증된 ID가 갖는 권한을 결정하는 프로세스입니다. 범위는 인증된 ID가 승인되었는지 여부를 결정하는 데 사용됩니다.

여기에 보이는 예시에서 애플리케이션 A와 B에는 인증된 ID(또는 서비스 계정)가 포함되어 있습니다. 두 애플리케이션 모두 **Cloud Storage** 버킷을 사용하려고 한다고 가정해 보겠습니다. 이 애플리케이션들은 각각 **Google** 승인 서버에서 액세스를 요청하고 액세스 토큰을 받습니다. 애플리케이션 A는 읽기 전용 범위의 액세스 토큰을 수신하므로 **Cloud Storage** 버킷에서 읽을 수만 있습니다. 그와는 달리 애플리케이션 B는 읽기/쓰기 범위의 액세스 토큰을 수신하므로 **Cloud Storage** 버킷에서 데이터를 읽고 수정할 수 있습니다.

VM 범위 맞춤설정

Identity and API access ?

Service account ?

Compute Engine default service account ▼

Access scopes ?

- ☐ Allow default access
- ☐ Allow full access to all Cloud APIs
- ☒ Set access for each API

BigQuery

None

Bigtable Admin

None

Bigtable Data

None

Cloud Datastore

None

- 범위는 인스턴스가 생성된 후에 변경할 수 있습니다.
- 사용자가 만든 서비스 계정의 경우 대신 IAM 역할을 사용하세요.

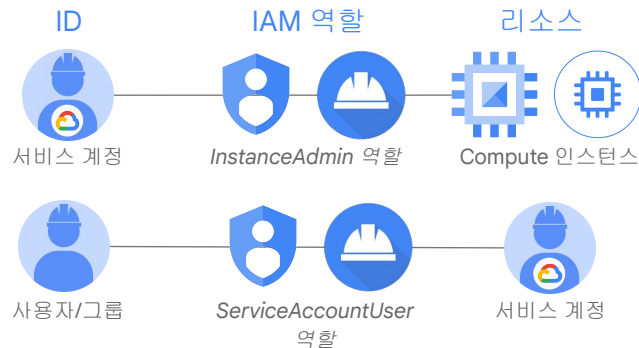
Google Cloud

이 스크린샷과 같이, 기본 서비스 계정을 사용하여 인스턴스를 만들 때 범위를 맞춤설정할 수 있습니다. 이러한 범위는 인스턴스가 생성된 후에 인스턴스를 중지하여 변경할 수 있습니다. 액세스 범위는 사실 VM에 권한을 지정하는 기존 방법입니다. IAM 역할 이전에는 액세스 범위가 서비스 계정에 권한을 부여하기 위한 유일한 방법이었습니다.

사용자가 만든 서비스 계정의 경우 대신 IAM 역할을 사용하여 권한을 지정하세요.

서비스 계정 권한

- 기본 서비스 계정: 기본 및 사전 정의된 역할
- 사용자가 만든 서비스 계정: 사전 정의된 역할
- 서비스 계정의 **역할**은 그룹 또는 사용자에게 할당 가능



Google Cloud

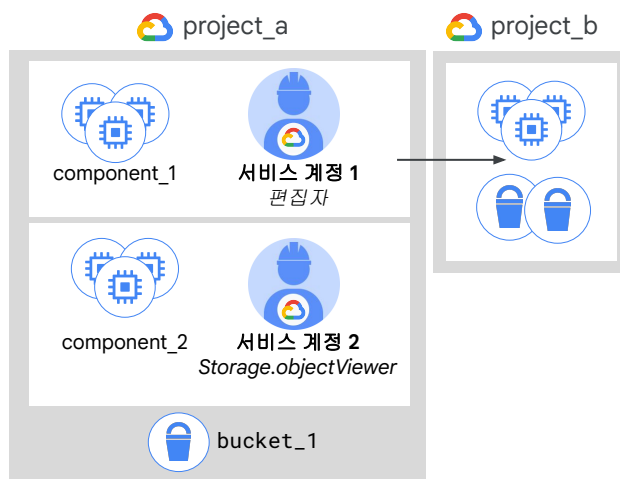
서비스 계정 간의 또 다른 차이점을 얘기하자면, 기본 서비스 계정은 기본 및 사전 정의된 **IAM** 역할을 모두 지원하지만 사용자가 만든 서비스 계정은 사전 정의된 **IAM** 역할만 사용한다는 것입니다.

이제 서비스 계정의 역할을 그룹이나 사용자에게 할당할 수도 있습니다. 이 슬라이드에 나와 있는 예시를 살펴보겠습니다. 먼저 가상 머신 인스턴스 및 디스크의 생성, 수정, 삭제 권한이 있는 **InstanceAdmin** 역할을 가진 서비스 계정을 생성합니다. 그런 다음, 이 서비스 계정을 리소스로 취급하고 사용자 또는 그룹에 서비스 계정 사용자 역할을 제공하여 누가 이를 사용할 수 있는지 결정합니다. 이렇게 하면 해당 사용자는 주어진 서비스 계정 역할을 수행하여 가상 머신 인스턴스 및 디스크를 생성, 수정 및 삭제할 수 있습니다.

서비스 계정에 서비스 계정 사용자 역할이 있는 사용자는 서비스 계정에서 액세스할 수 있는 모든 리소스에 액세스할 수 있습니다. 따라서 사용자나 그룹에 서비스 계정 사용자 역할을 부여할 때는 주의해야 합니다.

예: 서비스 계정과 IAM

- component_1을 실행하는 VM에는 서비스 계정 1을 사용하여 project_b에 대한 편집자 액세스 권한이 부여됩니다.
- component_2를 실행하는 VM에는 서비스 계정 2를 사용하여 bucket_1에 대한 objectViewer 액세스 권한이 부여됩니다.
- 서비스 계정 권한은 VM을 다시 생성하지 않고도 변경할 수 있습니다.



Google Cloud

여기에 또 다른 예시가 있습니다. component_1을 실행하는 VM에는 서비스 계정 1을 사용하여 project_b에 대한 편집자 액세스 권한이 부여됩니다. component_2를 실행하는 VM에는 격리된 서비스 계정 2를 사용하여 bucket_1에 대한 objectViewer 액세스 권한이 부여됩니다. 이렇게 하면 VM을 다시 만들지 않고도 VM에 대한 권한 범위를 지정할 수 있습니다.

기본적으로 IAM을 사용하면 각각의 마이크로서비스를 나타내는 서비스 계정을 생성함으로써 프로젝트를 상이한 리소스에 대한 액세스 권한을 갖는 서로 다른 마이크로서비스로 분할할 수 있습니다. 사용자를 대신하여 Google Cloud에서 보안을 관리하므로, VM이 생성될 때 서비스 계정을 VM에 할당하고 사용자 인증 정보가 올바르게 관리되고 있는지 확인할 필요가 없습니다.

그럼 서비스 계정은 어떻게 인증되는 것일까요?

서비스 계정 키의 두 가지 유형

Google 관리형 서비스 계정

- 모든 서비스 계정에 Google이 관리하는 키가 있습니다.
- Google은 키의 공개 부분과 비공개 부분을 모두 저장합니다.
- 각 공개 키는 최대 2주 동안 서명에 사용할 수 있습니다.
- 비공개 키는 절대로 직접 액세스할 수 없습니다.

사용자 관리형 서비스 계정

- Google에서는 사용자가 관리하는 키의 공개 부분만 저장합니다.
- 비공개 키의 보안에 대한 책임은 사용자에게 있습니다.
- 서비스당 최대 10개의 사용자 관리형 서비스 계정 키를 만들 수 있습니다.
- IAM API, `gcloud` 또는 콘솔을 통해 관리할 수 있습니다.

서비스 계정 키에는 다음과 같은 두 가지 유형이 있습니다.

기본적으로 Google Cloud 내에서(예: Compute Engine 또는 App Engine에서) 서비스 계정을 사용할 때 Google은 서비스 계정의 키를 자동으로 관리합니다. 하지만 Google Cloud 외부에서 서비스 계정을 사용하고 싶거나 다른 순환 주기를 원하는 경우 자체 서비스 계정 키를 수동으로 만들고 관리하는 것도 가능합니다.

서비스 계정 키의 두 가지 유형

Google 관리형 서비스 계정

- 모든 서비스 계정에 Google이 관리하는 키가 있습니다.
- Google은 키의 공개 부분과 비공개 부분을 모두 저장합니다.
- 각 공개 키는 최대 2주 동안 서명에 사용할 수 있습니다.
- 비공개 키는 절대로 직접 액세스할 수 없습니다.

사용자 관리형 서비스 계정

- Google에서는 사용자가 관리하는 키의 공개 부분만 저장합니다.
- 비공개 키의 보안에 대한 책임은 사용자에게 있습니다.
- 서비스당 최대 10개의 사용자 관리형 서비스 계정 키를 만들 수 있습니다.
- IAM API, `gcloud` 또는 콘솔을 통해 관리할 수 있습니다.

Google Cloud

모든 서비스 계정에는 **Google**이 관리하는 키 쌍이 있습니다.

Google은 **Google** 관리형 서비스 계정 키의 공개 부분과 비공개 부분을 모두 저장하고 정기적으로 순환시킵니다.

각 공개 키는 최대 **2주** 동안 서명에 사용할 수 있습니다.

비공개 키는 항상 에스크로에 안전하게 보관되며 직접 액세스할 수 없습니다.

서비스 계정 키의 두 가지 유형

Google 관리형 서비스 계정

- 모든 서비스 계정에 Google이 관리하는 키가 있습니다.
- Google은 키의 공개 부분과 비공개 부분을 모두 저장합니다.
- 각 공개 키는 최대 2주 동안 서명에 사용할 수 있습니다.
- 비공개 키는 절대로 직접 액세스할 수 없습니다.

사용자 관리형 서비스 계정

- Google에서는 사용자가 관리하는 키의 공개 부분만 저장합니다.
- 비공개 키의 보안에 대한 책임은 사용자에게 있습니다.
- 서비스당 최대 10개의 사용자 관리형 서비스 계정 키를 만들 수 있습니다.
- IAM API, `gcloud` 또는 콘솔을 통해 관리할 수 있습니다.

Google Cloud

Google Cloud 외부에서 사용할 수 있는 하나 이상의 사용자 관리 키 쌍('외부' 키라고도 함)을 만들 수 있습니다. Google에서는 사용자가 관리하는 키의 공개 부분만 저장합니다.

사용자는 비공개 키에 대한 보안 책임을 지며 수동 또는 프로그래매틱 방식의 키 순환과 같은 기타 관리 작업을 수행할 책임이 있습니다.

사용자는 원활한 키 순환을 위해 서비스 계정당 최대 10개의 서비스 계정 키를 만들 수 있습니다.

사용자가 관리하는 키는 IAM API, `gcloud` 명령줄 도구 또는 Google Cloud 콘솔의 서비스 계정 페이지를 통해 관리할 수 있습니다.

사용자 관리형 키를 안전하게 보관하는 것이 중요하며
이는 만든 사람의 책임



주의: Google은 사용자 관리형 비공개 키를
저장하지 않습니다. 분실한 경우 Google에서
복구를 도와드릴 수 없습니다.

Google은 사용자 관리형 비공개 키를 저장하지 않으므로 분실한 경우 Google에서
복구를 도와드릴 수 없습니다.

이러한 키를 안전하게 보관하고 키 순환을 수행할 책임은 여러분에게 있습니다.

사용자 관리형 키는 최후의 수단으로 사용해야 합니다. 단기 서비스 계정 사용자
인증 정보(토큰) 또는 서비스 계정 가장과 같은 다른 대안을 고려하세요.

gcloud 명령줄 도구를 사용하여 서비스 계정과 연결된 모든 키를 빠르게 나열 가능

```
gcloud iam service-accounts keys list --iam-account user@email.com
```

이 슬라이드에 나와 있는 **gcloud** 명령줄을 사용하면 빠르고 쉽게 특정 서비스 계정과 연결된 모든 키를 나열할 수 있습니다.



조직 액세스 제한

이제 조직 액세스 제한에 대해 이야기해 보겠습니다.

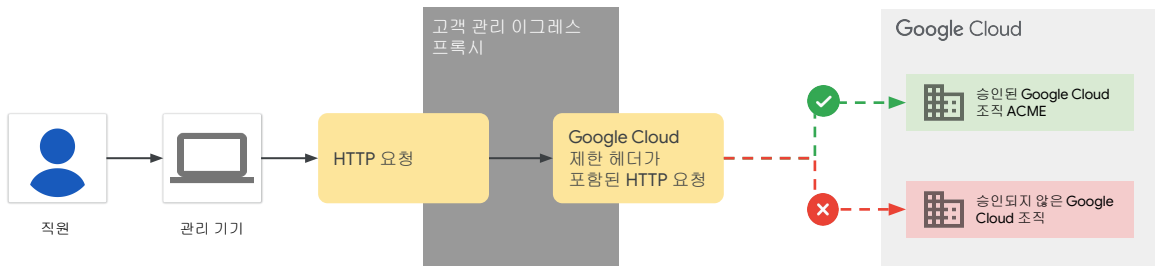
조직 액세스 제한을 사용하면 피싱 또는 내부자 공격을 통한 데이터 무단 반출을 방지할 수 있습니다.

Google Cloud

조직 액세스 제한 기능을 사용하면 피싱 또는 내부자 공격을 통한 데이터 무단 반출을 방지할 수 있습니다.

조직의 관리 기기인 경우, 조직 액세스 제한 기능은 승인된 **Google Cloud** 조직의 리소스로만 액세스를 제한합니다.

조직 액세스 제한



Google Cloud

조직에서는 승인된 **Google Cloud** 조직의 리소스로만 직원 액세스를 제한할 필요가 있습니다. **Google Cloud**를 관리하는 **Google Cloud** 관리자와 이그레스 프록시를 구성하는 이그레스 프록시 관리자는 협력하여 조직 액세스 제한을 설정합니다.

관리 기기에는 회사의 조직 정책이 적용됩니다. 조직의 직원은 관리 기기를 사용하여 조직 리소스에 액세스합니다. 이그레스 프록시 관리자는 관리 기기에서 시작된 모든 요청에 조직 액세스 제한 헤더를 추가하도록 프록시를 구성합니다. 이 프록시 구성을 사용하면 사용자가 승인되지 않은 **Google Cloud** 조직의 **Google Cloud** 리소스에 액세스할 수 없습니다. **Google Cloud**의 조직 액세스 제한 기능은 조직 액세스 제한 헤더에 대한 모든 요청을 검사하고 액세스되는 조직을 바탕으로 요청을 허용하거나 거부합니다.

조직 액세스 제한을 사용하면 직원이 다른 조직이 아닌 사용자의 **Google Cloud** 조직의 리소스에만 액세스하도록 조직 내 직원의 액세스 권한을 제한할 수 있습니다. 또한 직원이 **Cloud Storage** 리소스에서 읽을 수 있도록 허용하되 **Google Cloud** 조직에 있는 리소스로만 직원 액세스를 제한하는 데 사용할 수도 있습니다. 또는 직원이 관리자의 **Google Cloud** 조직 외에 공급업체의 **Google Cloud** 조직에도 액세스할 수 있도록 허용할 수 있습니다.



IAM 권장사항

일상 업무에서 방금 배운 개념을 적용하는 데 도움이 되는 몇 가지 **IAM** 권장사항에 대해 이야기해 보겠습니다.

리소스 계층 구조의 이해 및 활용

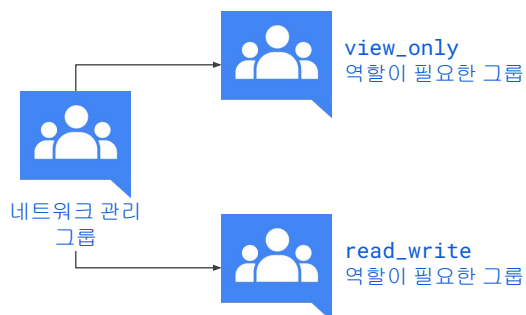
- 프로젝트를 사용하여 동일한 신뢰 경계를 공유하는 리소스를 그룹화합니다.
- 각 리소스에 부여된 정책을 확인하고 상속이 무엇인지 이해해야 합니다.
- 역할을 부여할 때 '최소 권한의 원칙'을 적용합니다.
- Cloud 감사 로그에서 정책을 감사합니다(setiampolicy).
- 정책에 사용되는 그룹 멤버십을 감사합니다.

먼저, 리소스 계층 구조를 이해하고 활용합니다.

- 구체적으로는 프로젝트를 사용하여 동일한 신뢰 경계를 공유하는 리소스를 그룹화합니다.
- 각 리소스에 부여된 정책을 확인하고 상속이 무엇인지 이해해야 합니다.
- 상속이 이뤄지므로 역할을 부여할 때는 '최소 권한의 원칙'을 적용합니다.
- 마지막으로 **Cloud** 감사 로그를 사용하여 정책을 감사하고 정책에 사용되는 그룹 멤버십을 감사합니다.

개인 대신 Google 그룹에 역할 부여

- IAM 정책을 변경하는 대신 그룹 멤버십을 업데이트합니다.
- 정책에 사용되는 그룹 멤버십을 감사합니다.
- IAM 정책에 사용되는 Google 그룹의 소유권을 제어합니다.



Google Cloud

개인이 아닌 그룹에 역할을 부여하는 것이 좋습니다. 이렇게 하면 IAM 정책을 변경하는 대신 그룹 멤버십을 업데이트할 수 있습니다. 그룹에 역할을 부여하는 경우 정책에서 사용되는 그룹 멤버십을 감사하고 IAM 정책에서 사용되는 Google 그룹의 소유권을 제어해야 합니다.

그룹을 여러 개 사용하면 제어하기가 좀 더 수월합니다. 이 슬라이드의 예시에는 네트워크 관리자 그룹이 있습니다. 이 그룹에는 Cloud Storage 버킷에 대한 read_write 역할도 필요한 구성원이 있는가 하면 read_only 역할만 필요한 구성원도 있습니다. 세 그룹 모두에서 개인을 추가 및 제거하면서 전체 액세스 권한을 제어할 수 있습니다. 따라서 그룹은 작업 역할과 관련될 뿐만 아니라 역할 할당을 위해서도 존재할 수 있습니다.

서비스 계정

- `serviceAccountUser` 역할을 부여할 때는 주의합니다.
- 서비스 계정을 만들 때 목적을 명확하게 식별하는 표시 이름을 지정합니다.
- 서비스 계정의 경우 이름 지정 규칙을 설정합니다.
- 키 순환 정책 및 방법을 설정합니다.
- `serviceAccount.keys.list()` 메서드로 감사합니다.

서비스 계정 사용에 대한 몇 가지 권장사항을 소개해드리겠습니다.

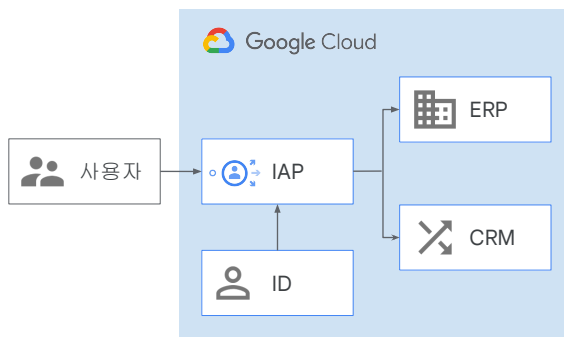
- 앞서서도 언급했듯이 서비스 계정 사용자 역할을 부여할 때는 매우 주의해야 합니다. 이 역할은 서비스 계정이 액세스할 수 있는 모든 리소스에 대한 액세스를 제공하기 때문입니다.
- 또한 서비스 계정을 만들 때 가능하면 확립된 이름 지정 규칙을 사용하여 목적을 명확하게 식별하는 표시 이름을 지정하는 것이 좋습니다.
- 키의 경우 `serviceAccount.keys.list()` 메서드로 키 순환 정책 및 메서드를 설정하고 키를 감사합니다.

IAP(Identity-Aware Proxy)

애플리케이션 및 리소스에 대한 액세스
제어 정책 시행:

- ID 기반의 액세스 제어
- HTTPS로 액세스할 수 있는
애플리케이션을 위한 중앙 승인 레이어

IAM 정책은 인증 후 적용됩니다.



Google Cloud

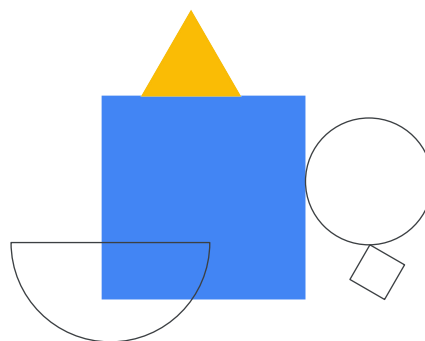
마지막으로 **IAP(Identity-Aware Proxy)**를 사용하는 것이 좋습니다. **IAP**를 사용하면 **HTTPS**로 액세스되는 애플리케이션에 대해 중앙 승인 레이어를 설정할 수 있으므로, 네트워크 수준의 방화벽을 사용하는 대신 애플리케이션 수준의 액세스 제어 모델을 사용할 수 있습니다.

IAP로 보호되는 애플리케이션 및 리소스는 올바른 **IAM** 역할을 가진 사용자 및 그룹만 프록시를 통해 액세스할 수 있습니다. **IAP**를 통해 애플리케이션 또는 리소스에 대한 액세스 권한을 사용자에게 부여할 경우, **VPN** 없이 사용 중인 제품으로 구현된 미세 조정된 액세스 제어가 적용됩니다. **IAP**는 오른쪽과 같이 사용자가 **IAP** 보안 리소스에 액세스를 시도할 때 인증 및 승인 검사를 수행합니다.

IAP에 대한 자세한 내용은 이 [문서 페이지](#)를 참조하세요.

실습 소개

IAM 살펴보기



Google Cloud

방금 배운 몇 가지 개념을 실습에서 적용해 보겠습니다.

실습 목표

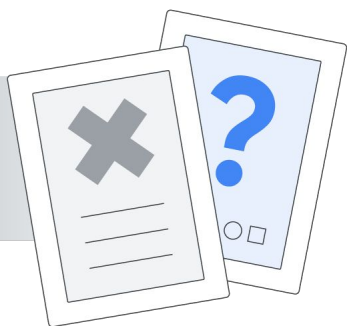
- 01 IAM을 사용하여 액세스 제어 구현하기
- 02 특정 기능 또는 리소스에 대한 액세스 제한하기
- 03 서비스 계정 사용자 역할 사용하기



Google Cloud

이 실습에서는 액세스 권한을 변경하기 위해 역할을 부여 및 취소해 봅니다. 특히 **IAM**을 사용하여 액세스 제어를 구현하고, 특정 기능 및 리소스에 대한 액세스를 제한하고, 서비스 계정 사용자 역할을 사용하게 됩니다.

이제 **IAM** 역할을 변경할 때마다 **Google Cloud** 콘솔이 실제 시스템보다 빠르게 새로고침됩니다. 따라서 구성원의 역할을 변경할 때 약간의 지연이 발생할 수 있습니다.



퀴즈



질문 1

질문

IAM에서 사용자 액세스를 관리하는 데 주로 사용되는 추상화는 무엇인가요?

- A. 임대, 주기적 사용 권한의 추상화
- B. 역할, 작업 역할의 추상화
- C. 사용자 인증 정보, 인증 토큰의 추상화
- D. 권한, 액세스 권한의 추상화

질문 1

정답

IAM에서 사용자 액세스를 관리하는 데 주로 사용되는 추상화는 무엇인가요?

- A. 임대, 주기적 사용 권한의 추상화
- B. 역할, 작업 역할의 추상화
- C. 사용자 인증 정보, 인증 토큰의 추상화
- D. 권한, 액세스 권한의 추상화



설명:

IAM 관리는 사용자 액세스 관리를 위해 사전 정의된 역할을 사용합니다. 역할은 보다 세분화된 권한으로 정의됩니다. 그러나 권한은 사용자에게 직접 적용되지 않으며 할당된 역할을 통해서만 적용됩니다.

질문 2

질문

다음 중 IAM 역할의 유형이 아닌 것은 무엇인가요?

- A. 기본 역할
- B. 사전 정의된 역할
- C. 커스텀 역할
- D. 고급 역할

질문 2

정답

다음 중 IAM 역할의 유형이 아닌 것은 무엇인가요?

- A. 기본 역할
- B. 사전 정의된 역할
- C. 커스텀 역할
- D. 고급 역할



설명:

IAM에는 기본 역할, 사전 정의된 역할, 커스텀 역할이라는 세 가지 역할 유형이 있습니다.

질문 3

질문

다음 중 IAM 구성원 유형이 아닌 것은 무엇인가요?

- A. Google 계정
- B. 서비스 계정
- C. Google 그룹
- D. 조직 계정
- E. Cloud ID 도메인
- F. Google Workspace 도메인

질문 3

정답

다음 중 IAM 구성원 유형이 아닌 것은 무엇인가요?

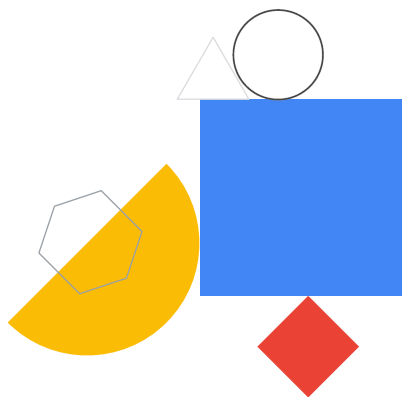
- A. Google 계정
- B. 서비스 계정
- C. Google 그룹
- D. 조직 계정**
- E. Cloud ID 도메인
- F. Google Workspace 도메인



설명:

구성원에는 5가지 유형, 즉 Google 계정, 서비스 계정, Google 그룹, Google Workspace 도메인, Cloud ID 도메인이 있습니다.

검토: Identity and Access Management



Google Cloud

이 모듈에서는 IAM에 대해 살펴보며 그 구성요소와 권장사항도 알아보았습니다.

IAM은 다른 Google Cloud ID 서비스를 기반으로 구축됩니다. 기업 ID의 생성 및 관리는 Workspace 관리자 또는 Cloud ID 인터페이스를 통해 이루어지며 일반적으로 Google Cloud 관리자가 아닌 사람이 처리합니다.

Google 그룹은 이 두 가지 비즈니스 직능이 공동작업할 수 있는 좋은 방법입니다. 역할을 설정하고 그룹에 할당하면 Workspace 관리자가 그룹의 멤버십을 관리합니다.

마지막으로 서비스 계정은 매우 유연하며 이를 통해 애플리케이션에 인프라 수준의 제어를 구축할 수 있습니다.

